

RESERVE BANK OF INDIA
DEPARTMENT OF REGULATION, CENTRAL OFFICE, MUMBAI
RBI/2024-25/155 DoR.ORG.REC.65/21.04.158/2024-25
September 29, 2024
Master Direction on Outsourcing of Information Technology Services

1. **Prohibited Outsourcing Activities:** Regulated Entities shall not outsource core management functions, including the decision-making authority on credit sanction, overall risk management, compliance oversight, and internal audit functions. The ultimate responsibility for outsourced IT operations rests entirely with the Board and Senior Management of the RE.
2. **Due Diligence and Concentration Risk:** REs shall perform rigorous financial, operational, and cybersecurity due diligence on service providers prior to signing outsourcing agreements. Material outsourcing arrangements must evaluate concentration risk and avoid over-dependency across core banking modules.
3. **Data Sovereignty and Cross-Border Storage:** The primary transactional databases and financial customer records of REs must be stored within the territorial borders of India. Where cross-border support or analytics is permitted, the service provider contract must explicitly guarantee that the Reserve Bank and its appointed auditors have unrestricted right of inspection and audit of systems.

4. Business Continuity and Disaster Recovery: Material IT outsourcing arrangements must include defined Recovery Time Objective (RTO) and Recovery Point Objectives (RPO). For critical payment and customer-facing banking services, the RTO shall not exceed 15 minutes and RPO shall not exceed 15 minutes. Disaster recovery drills with service providers must be conducted at least once annually.
5. Termination and Exit Clauses: All outsourcing contracts must incorporate clear exit strategies, transitional assistance requirements, and guaranteed return or destruction of proprietary data within 30 days of contract termination.
6. Sub-contracting Authorization: The service provider shall not sub-contract any material component of the outsourced service to a third party without prior written consent from the Regulated Entity.

7. Cloud Computing Architecture and Encryption: Regulated Entities migrating workloads to public or multi-tenant cloud service providers must ensure that data at rest and data in transit is encrypted using advanced algorithms (AES-256 minimum). Custom encryption keys (CMEK) must be held by the RE.
8. Audit and Access Rights: Contracts with IT service providers must explicitly grant the Regulated Entity, its internal and external auditors, and the Reserve Bank's supervisory teams unhindered physical and logical access to relevant infrastructure, logs, and
9. Incident Notification by Vendors: IT service providers must contractually commit to notify the Regulated Entity of any security data breach, or unauthorized access within two hours of detection.

10. Service Level Agreements (SLAs): Comprehensive metrics for system availability, response time, bug fixes, and patch management must be incorporated into SLAs with predefined financial penalties for non-compliance.

11. Offshore Service Providers: Where the service provider is located outside India, the RE must evaluate the legal and geopolitical risks of the foreign jurisdiction and ensure that regulatory actions by foreign authorities cannot block Indian bank records.

12. Board Review of Outsourcing: A comprehensive inventory of all material IT outsourcing arrangements and vendor performance shall be presented to the Board of Directors at least once every financial year.

Yours faithfully,

(Charulatha S. R.)

Chief General Manager